

SSH Intrusion & Privilege Escalation Incident Report

Date of Report: 05/09/2025

Date of Incident: 03/09/2025

Prepared By: Laiba Asad

Table of Contents

1. Preparation.....	3
2. Detection & Analysis.....	3
2.1 Victim Machine (Server1 – Target).....	3
2.2 Key Observations.....	7
3. Analysis of the Attack Technique.....	7
4. Executive Summary.....	8
5. Detection and Response Recommendations.....	8
5.1 Detection.....	8
5.2 Response.....	8
6. Lessons Learned.....	9

A complete investigation report on a brute force intrusion and subsequent malicious activity detected on server1.

1. Preparation

Incident Title: SSH Brute Force Intrusion on Server1

Date/Time: September 3–4, 2025 (23:10 – 02:11)

Affected Host: Server1 (192.168.1.156)

Attacker IP: 192.168.1.166

Service Targeted: SSH (Port 22)

Scope: Review Wazuh logs related to authentication failures, privilege escalation, and package tampering.

Tools Used: Wazuh log monitoring.

2. Detection & Analysis

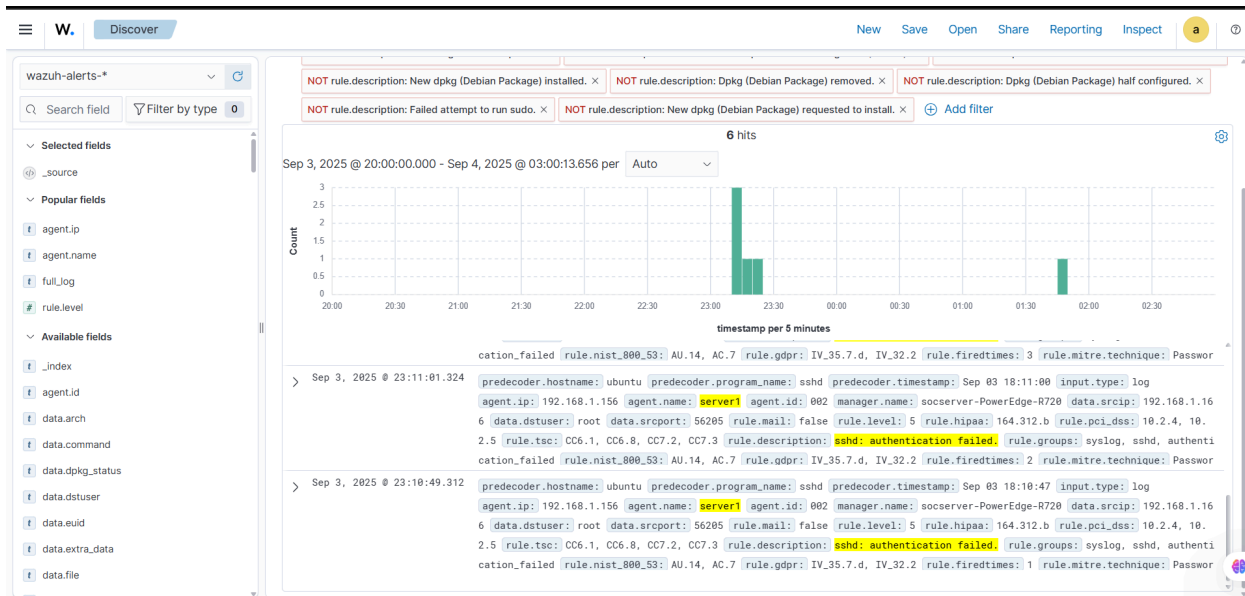
2.1 Victim Machine (Server1 – Target)

Timeline of Events

23:10 – 23:35 | Initial Authentication Failures

- 5 hits: SSH authentication failures (23:10:49, 23:11:01, 23:11:15, 23:19:43, 23:21:09).
- 2 hits: PAM user login failed (23:10:47, 23:19:41).
- 1 hit: Connection reset by peer (23:11:15).
- 1 hit: “User missed password more than one time” (23:11:15).
- 5 hits: Attempts to log in with invalid user victimuser (23:35:08 – 23:35:26).

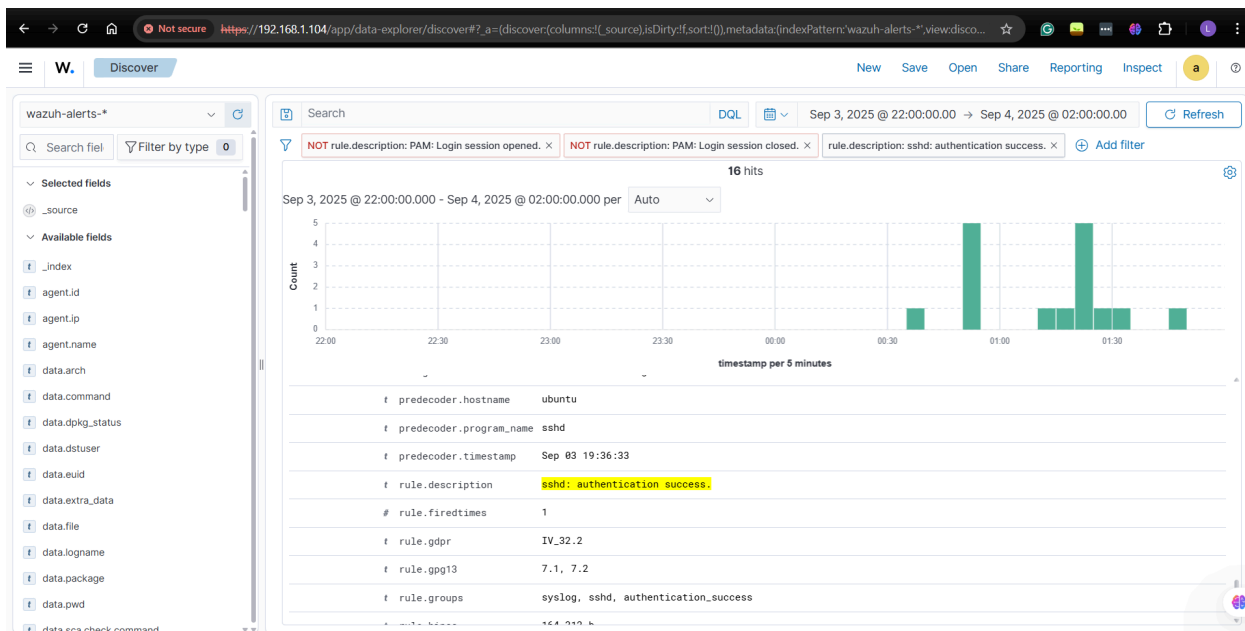
Automated brute force attempts with multiple usernames and repeated password guessing.



Reference

00:36 | First Successful Access

- Successful authentication for user server1 from 192.168.1.166.
- PAM session opened for user server1.
- The attacker gained a valid interactive session.

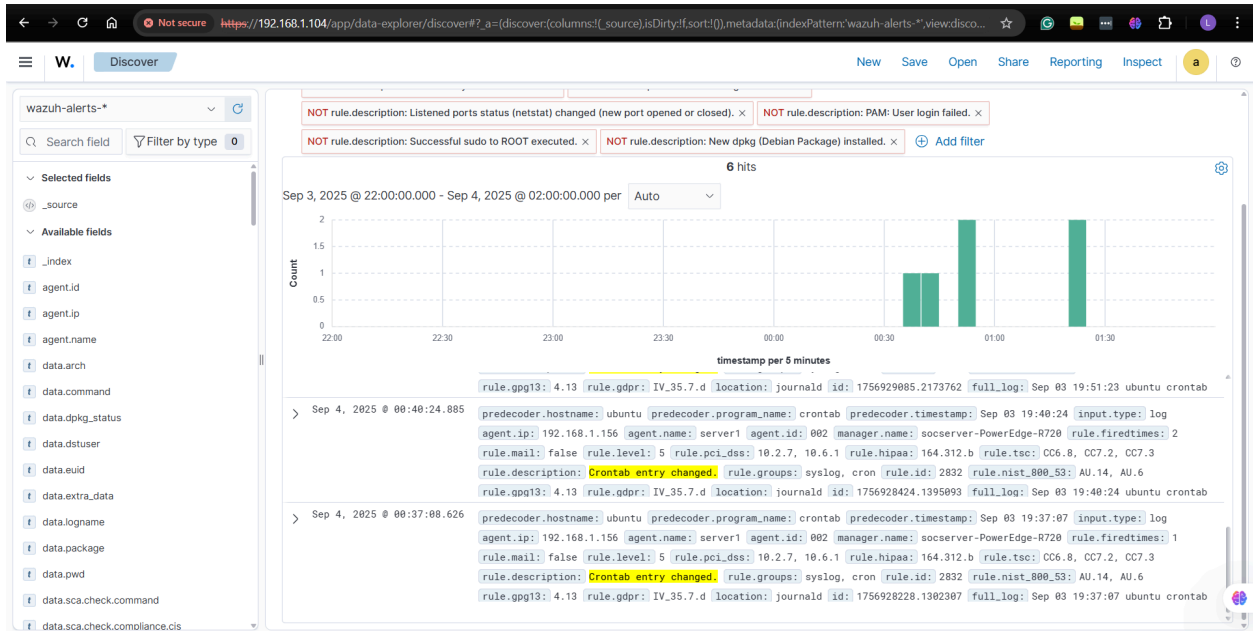


Reference

00:37 – 00:54 | Crontab and Session Activity

- Multiple crontab entries changed (00:37:08, 00:40:24, 00:51:25, 00:52:47).
- Multiple PAM login sessions opened (00:51:25 – 00:54:09).

The attacker establishes persistence by modifying cron jobs.



Reference

01:08 | Privilege Escalation & Package Tampering

First successful sudo to root detected.

- dpkg logs show sudo and ubuntu-minimal packages removed and reinstalled.
- Evidence of system manipulation targeting critical security components.



Reference

01:20 – 01:24 | Continued Cron Changes

- Additional crontab entries modified.
- Indicates persistence mechanisms were updated after privilege escalation.

01:29 – 01:35 | Failed Privilege Escalation Attempts

Multiple failed attempts:

- Wrong password when switching UID (su).
- Failed sudo executions.

Suggests unstable root control and repeated attempts to regain/reinforce privilege escalation.

01:45 – 01:49 | Continued Sudo Usage

- Logs show additional sudo commands executed as root.
- Indicates attacker maintained privileged access.

02:11 | Persistence & Package Install Attempts

- Multiple dpkg installation requests recorded (at least 5 hits at 02:11:48–02:11:50).
- Suggests installation of malicious tools/backdoors for persistence.

2.2 Key Observations

- The attack began with brute force attempts on SSH.
- First compromise occurred at 00:36 with user server1.
- Attacker escalated to root at 01:08 via sudo.
- System packages (sudo, ubuntu-minimal) were tampered with.
- Multiple crontab modifications indicate persistence attempts.
- Attacker's escalation was unstable, shown by failed su/sudo attempts.
- By 02:11, the attacker attempted to install additional software (possible backdoors).

3. Analysis of the Attack Technique

Initial Access (Brute Force)

Attacker repeatedly attempted SSH logins until successful (MITRE T1110 – Brute Force).

Persistence

Multiple crontab modifications suggest scheduled task creation for persistence (MITRE T1053 – Scheduled Task/Job).

Privilege Escalation & Defense Evasion

- Successful use of sudo to root.
- Attempted removal of sudo package to limit administrator response (MITRE T1548.003 – Sudo).

System Manipulation

Package removal and installation of dpkg/apt packages. Likely to install tools or weaken defenses (MITRE T1609 – Container/Service Manipulation, or T1072 – Software Deployment Tools abuse).

Impact

- Partial compromise of root privileges.
- System tampering and potential backdoor installation.

4. Executive Summary

Between **23:10 on September 3 and 02:11 on September 4, 2025**, server1 was compromised via an **SSH brute force attack** originating from 192.168.1.166.

The attack began with numerous failed login attempts against both valid and invalid users. At 00:36, the attacker successfully logged in as server1. Shortly after, cron jobs were modified, likely as persistence mechanisms.

By 01:08, the attacker escalated privileges to root via sudo, then tampered with critical system packages, including sudo and ubuntu-minimal. Between 01:20 and 01:24, further cron modifications were made, strengthening persistence.

The attacker attempted multiple times to stabilize privilege escalation through failed su/sudo attempts but continued to execute commands as root at 01:45. At 02:11, multiple dpkg installation requests were logged, consistent with attempts to install additional tools or backdoors.

This confirms a **successful SSH intrusion, partial root compromise, cron-based persistence, and system tampering.**

5. Detection and Response Recommendations

5.1 Detection

- Enhance Wazuh rules for crontab changes and dpkg tampering.
- Monitor for unusual package removal/install activity.

5.2 Response

- Immediately block the attacker IP (192.168.1.166).
- Reset credentials for the compromised account (server1).
- Audit crontab for malicious entries.
- Check installed packages for unauthorized software.
- Reinstall and harden the affected host if root compromise is confirmed.

6. Lessons Learned

- Weak authentication controls enabled brute force intrusion.
- Lack of intrusion prevention allowed prolonged attack attempts.
- No restrictions on SSH-enabled direct access by attackers.
- Critical system binaries (sudo, dpkg) were manipulated; stronger file integrity monitoring is needed.
- Cron job monitoring should be prioritized, as attackers leveraged it for persistence.